

We Need to Integrate and Unify for AI Security

Sven Cattell

February 12, 2025

Abstract

The value of AI companies is largely the security layers they provide. This article discusses the importance of model reliability and a method of trusting the performance for commercial viability of large language models and proposes an integrated approach to AI security.

Note

I'm the organizer behind the 2023 Generative Red team with the Biden Administration. I care about security of AI models and making sure this technology does what is best for the people that built and use it. What I promised during that event was that we would apply a CVE like process to the findings. We defined that in the lead up to the event and I later published it as a paper [Cattell et al., 2024].

Fundamentally, I believe that we treat the model cards as implicit contracts that define what the model is supposed to do [Mitchell et al., 2019]. A flaw is a violation of that contract. This is inevitable, AI is complex and there are many edge cases. Even in simple discriminative AI. I worked on classifying Malware and there will always be new strains of malware that bypass our models. In the traditional security world we take reports when we violate the implicit contract of delivering secure software, and fix it. This is more than an admission that software vendors make mistakes. It's a collaborative process for improving software while providing liability coverage for innovations that we need.

During the lead up to that event I realized that we were unable to actually implement a CVE process. The profile of the event, and the collaborators I chose, meant that safety was more important than learning from the unique environment that DEF CON offers. We followed a prescriptive set of challenges. The AI Risk Management Framework that NIST developed is prescriptive in it's requirements [National Institute of Standards and Technology, 2023]. It tells the vendors what they should do and make with their models. We followed that document and the AI Bill Of Rights in constructing our challenges [Office of Science and Technology Policy, 2022]. I think it's important to build AI that does good, but I think that's really up to the model vendors and their customers. There are some harms that need to be regulated, such as child sexual

abuse material but that is already managed by existing laws [U.S. Department of Justice, 2024].

What we need is to use the existing culture of disclosure. Instead of just talking about it with a bunch of policy heads, I experimented with the implementation of contract based flaws at GRT2 with a lower profile and a different set of partners. Allan Institute for AI chose the model card, we just facilitated the findings as it should be. We found that the ecosystem is not ready for this. Evaluations need to be made well for this concept to work. So, we're red teaming evaluations next. We will build this ecosystem of evaluations from the open source ones that are out there and build it to demonstrate the various uses of AI and how good it is at those tasks. As a mathematician with a PhD who codes complex geometric ideas into my products, it's not ready to take over for complex mathematics yet. It will get there. I want to build and maintain that benchmark in an open and collaborative way.

The openness is important because it is just cheaper. Disclosure was embraced by Microsoft and Google because it's the cheapest way to manage inevitable vulnerabilities in their products. Evaluations have mistakes too and no one can fix them if they can't open them up and look inside. I have had several conversations with executives at large AI companies that complained that evaluations are expensive and broken.

The pitch for the GRT has always been the motto: sunlight is the best disinfectant.

1 Introduction

An LLM like DeepSeek is a good demonstration of technical talent, but it's unusable for most commercial applications. **Model reliability is needed for LLMs to become commercially viable.** If we want agents to help manage our calendars or write code we need them to be secure and reliable. If we want customer service chatbots we need to know they're not going to expose deployers to liability by insulting their customer or offering to sell them a truck for \$1 [Lopez, 2023]. Managing this risk is different to traditional security as the attack surface is nearly infinite. Preventing a black box no one really understands from misbehaving when adversaries are controlling the inputs is impossible. However, the ML security community has over 20 years of experience with AI risk management and has a track record of securing AI models against persistent adversaries. Mature teams focus on discovering and minimizing the impact of attacks once they've reached a suitable level of robustness. And it works. Established AI models are far more reliable, just look at the hallucination rate of the latest model release from Google [Vectara, 2024, Hughes, 2023]. However, there's public mistrust [Fried, 2024] in AI, and as we deploy these systems we will find more flaws that need to be addressed. The challenge we face with LLMs is proving to customers and the public that these models are ready to use in their applications.

The solution people turned to was AI Red teaming. This basically meant

that the risk assessment of the model systems would be done by a third party. After running the first two Generative Red Teams [Sven Cattell, 2024, Cattell, 2024] at DEF CON 31 and 32, I believe that the focus on AI red teaming is missing the forest for the trees. A company’s traditional software reliability is proven by the Coordinated Vulnerability Enumeration (CVE) [David E. Mann, 1999] and other Vulnerability Disclosure Programs (VDP). A penetration test report from a consulting firm that red teamed some software is an indicator they’ve done the work to make their software secure, but it’s all for naught if a major vulnerability is discovered after release. Requiring submission to a single gate keeper that blocks the release until they’ve done an assessment is just red tape if their report isn’t comprehensive. While there will always be an edge case that the assessor missed, the effective way to prove security is to do your best before release and then effectively respond to your mistakes. The ecosystem and practices of disclosure is how companies prove that they build secure systems.

This is effective because it doesn’t stop innovation. The prospect of public documentation incentivizes an investment in security where appropriate. Folks who want to move fast and break things can. Institutions with a reputation to uphold will invest in security. No one tells you what to do, they just record when you screw up. This notification system, and the culture that surrounds it, is extremely efficient at securing our systems over the long term. It helps downstream developers and consumers who need to know about vulnerabilities to mitigate their effect. It lowers the costs for vendors because best efforts are all that’s needed. And best of all, it doesn’t impact innovation.

We need to bring this to AI.

We tested AI vulnerability reporting at DEF CON 32’s second GRT. Before the event we identified two major problems which we addressed. First, identifying reportable AI system issues is difficult, which we addressed by defining model intent in the model card. Second, these are statistical beasts which makes proving and documenting AI errors difficult. The solution involved single-topic reports using the UK AISI Inspect framework [Institute, 2024]. We paid bounties for good reports of violations of model card statements that were well supported by an Inspect dataset. There was a language barrier between the data scientists reviewing submissions and DEF CON attendees, but once we overcame this, the feedback we received was overwhelmingly positive. Hackers enjoy discovering idiosyncrasies in the model’s behavior and building arguments as much as they enjoy other puzzles.

This approach revealed its own problems. Creating the model card was challenging due to a non-existent standard, and the evaluations that were used to support the intent statements didn’t always align well with researchers’ goals. Even when the evaluations did align they were incomplete. In particular, Harm-bench [Team, 2024] had gaps in areas like malicious code tasks and copyright violations. Going forward we need more test coverage with smaller focused evaluations that can be combined.

However the most important finding is: the idea of taking reports of flaws against a model using a documented “contract” supported with evaluations doesn’t scale. Reports can impact several different aspects of this proposed pro-

cess and individual companies handling them manually would be onerous. A report could indicate that a broad category of evaluations missed a vital sub-category. This would impact the model card and evaluation system, but not the model. For example, a new class of vulnerabilities is discovered and the old 'malicious code tasks' evaluation category does not include them. Another report could indicate that an evaluation made a mistake and needs some additional samples to appropriately test the models. This is most likely discovered by a flaw in a model and would impact the evaluation and model but not the model card. Appropriately directing the creation of new evaluations and updating the model card standard needs to be handled at a higher level.

Fortunately, security has already solved some of these problems. The scope of "vulnerability" is very broad and we deal with this through the Common Weakness Enumeration (CWE) [MITRE, 2024]. It is a taxonomy of all known weaknesses in software, and is essential to handling CVEs. It is updated through a transparent process managed by the CWE committee regularly. For AI models we don't need to document weaknesses, but uses and restrictions. We already create evaluations with uses and restrictions in mind, so a taxonomy of use is a natural place to start. These need to be tied to evaluations that are in standard, yet flexible, formats. Those evaluations need to be red teamed, and bounties need to be awarded against them. Model vendors then can choose what uses and restrictions they want their model to support, and ignore the rest. This could be made as simple as a menu of checkboxes that automatically creates a model card that the public can use. This is boiling the ocean, but there are great potential benefits for having a unified reporting ecosystem. Having this ecosystem be robust and coordinated means releases like DeepSeek would be immediately evaluated for trust and security and found to be lacking.

We need to iterate on the GRT at a small scale one more time. A collaborative live bug bash at DEF CON or NeuRIPS that tests the next version of these ideas is the best crucible to refine these processes to the point where we can set up an AI disclosure ecosystem.

References

- Sven Cattell. Generative red team 2, 2024. URL <https://grt.aivillage.org/announcement>.
- Sven Cattell, Avijit Ghosh, and Lucie-Aimée Kaffee. Coordinated flaw disclosure for ai: Beyond security vulnerabilities, 2024. URL <https://arxiv.org/abs/2402.07039>.
- Steven M. Christey David E. Mann. Towards a common enumeration of vulnerabilities. *The MITRE Corporation*, 1999. URL <https://www.cve.org/Resources/General/Towards-a-Common-Enumeration-of-Vulnerabilities.pdf>.

- Ina Fried. Exclusive: Public trust in ai is sinking across the board, 3 2024. URL <https://www.axios.com/2024/03/05/ai-trust-problem-edelman>.
- Simon Hughes. Cut the bull... detecting hallucinations in large language models, 2023. URL <https://www.vectara.com/blog/cut-the-bull-detecting-hallucinations-in-large-language-models>.
- UK AI Safety Institute. Aisi inspect framework, 2024. Framework for structured reporting of AI model vulnerabilities.
- Jonathan Lopez. Gm dealer chat bot agrees to sell 2024 Chevy Tahoe for \$1, 12 2023. URL <https://gmauthority.com/blog/2023/12/gm-dealer-chat-bot-agrees-to-sell-2024-chevy-tahoe-for-1/>.
- Margaret Mitchell, Simone Wu, Andrew Zaldivar, Parker Barnes, Lucy Vasserman, Ben Hutchinson, Elena Spitzer, Inioluwa Deborah Raji, and Timnit Gebru. Model cards for model reporting. In *Proceedings of the Conference on Fairness, Accountability, and Transparency*, FAT* '19, page 220–229. ACM, January 2019. doi: 10.1145/3287560.3287596. URL <http://dx.doi.org/10.1145/3287560.3287596>.
- MITRE. Common weakness enumeration, 2024. URL <https://cwe.mitre.org/>.
- National Institute of Standards and Technology. Artificial intelligence risk management framework (AI RMF 1.0), 1 2023. URL <https://www.nist.gov/itl/ai-risk-management-framework>. A voluntary framework to better manage risks to individuals, organizations, and society associated with artificial intelligence.
- Office of Science and Technology Policy. Blueprint for an ai bill of rights: Making automated systems work for the american people. <https://www.whitehouse.gov/wp-content/uploads/2022/10/Blueprint-for-an-AI-Bill-of-Rights.pdf>, 10 2022.
- Austin Carson Sven Cattell, Rumman Chowdhury. Generative red team, 2024. URL <https://aivillage.org/generative%20red%20team/generative-red-team/>.
- HarmBench Team. Harmbench: A standardized evaluation framework for red teaming llms, 2024. URL <https://www.harmbench.org/>.
- U.S. Department of Justice. Man arrested for producing, distributing, and possessing AI-generated images of minors engaged in sexually explicit conduct, 5 2024. URL <https://www.justice.gov/archives/opa/pr/man-arrested-producing-distributing-and-possessing-ai-generated-images-minors-engaged>.
- Vectara. Hallucination leaderboard, 2024. URL <https://github.com/vectara/hallucination-leaderboard>.